

Security+ 1.1 · Security Controls

Mestre CyberSec — PDF baseado na aula do Professor Messer · 1.1 — Security Controls (11:48) · [vídeo original ↗](#) · [YouTube ↗](#)

Controle = qualquer medida que evita, avisa, conserta ou compensa. 4 CATEGORIAS (by means): Technical (ferramenta), Managerial (documento/política), Operational (pessoas no dia-a-dia), Physical (barreira física). 6 TIPOS (by purpose): Preventive (barra antes), Deterrent (desanima), Detective (avisa depois), Corrective (repara), Compensating (plano B), Directive (direciona). A prova dá um CENÁRIO e pede a classificação nas duas dimensões.

💡 Highlights que a prova cobra

- Matriz 4×6 = a tabela mental da aula
- Preventive barra ANTES — Detective AVISA — Corrective CONCERTA
- Compensating: usa MEIOS DIFERENTES quando o ideal não dá — temporário
- Directive = o mais fraco: 'authorized personnel only' não barra ninguém
- Antivírus: technical + preventive e detective dependendo do modo
- Extintor de incêndio = corrective — repara durante, NÃO previne

🎯 Dicas de prova

- Gatilhos: 'after the event' → corrective · 'discourage' → deterrent · 'identifies/logs' → detective · 'alternative approach' → compensating
- A pergunta do Messer: 'what CATEGORY does it fit in (technical/managerial/operational/physical) AND what TYPE?'

Cenário clássico: Um cenário típico: 'organização exige dois administradores autorizem pagamento' → compensating/managerial (separation of duties). 'Restaura backup após ransomware' → corrective/technical. 'Placa sem fechadura: authorized personnel only' → directive/physical.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?", o: ["BEC / CEO fraud (fraude do CEO)", "Whaling", "Vishing", "Tailgating"], c:0, e: "BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima, não a máscara usada). Vishing é golpe por voz/telefone; tailgating é entrar atrás de alguém numa porta.", {id:"s102",t:"secplus",d:"d1",q:"Malware que criptografa teus arquivos e exige pagamento pra devolver é:", o: ["Spyware", "Ransomware", "Rootkit", "Worm"], c:1, e: "Ransomware sequestra os dados por criptografia e cobra resgate. Spyware espiona; rootkit se esconde no sistema com privilégio; worm se autopropaga na rede.", {id:"s103",t:"secplus",d:"d1",q:"Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:", o: ["CVE pública", "Zero-day", "Backdoor", "Falso positivo"], c:1, e: "Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção.", {id:"s104",t:"secplus",d:"d1",q:"Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:", o: ["Ataque on-path (MITM)", "Negação de serviço", "SQL injection", "Força bruta"], c:0, e: "On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas.", {id:"s105",t:"secplus",d:"d1",q:"Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:", o: ["Escassez", "Autoridade + urgência", "Prova social", "Reciprocidade"], c:1, e: "Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro.", {id:"s106",t:"secplus",d:"d1",q:"Injeção de comando SQL num campo de login explora principalmente a falta de:", o: ["Criptografia do disco", "Validação de entrada (input)", "Backup", "Antivírus"], c:1, e: "SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa.", // ===== SECURITY+ D2 — Arquitetura ===== {id:"s201",t:"secplus",d:"d2",q:"O princípio 'nunca confie, sempre verifique' — mesmo dentro da rede — é o modelo:", o: ["Defesa em profundidade", "Zero Trust", "Air gap", "Menor privilégio"], c:1, e: "Zero Trust assume que ninguém é confiável por padrão, nem quem já está dentro. Verifica cada acesso. Menor privilégio é complementar, mas é outro conceito.", {id:"s202",t:"secplus",d:"d2",q:"Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:", o: ["Menor privilégio", "Separação de funções", "Rotação de cargo", "Need-to-know geográfico"], c:0, e: "Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida.", {id:"s203",t:"secplus",d:"d2",q:"Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:", o: ["VLAN de voz", "DMZ (screened subnet)", "VPN", "Intranet"], c:1, e: "DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o

interno."}, {id:"s204",t:"secplus",d:"d2",q:"Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:", o:["Zero Trust","Defesa em profundidade","Fail-open","Segurança por obscuridade"],c:1, e:"Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger)."}, // ===== SECURITY+ D3 — Implementação ===== {id:"s301",t:"secplus",d:"d3",q:"Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o: ["Telnet","SSH","FTP","HTTP"],c:1, e:"SSH (porta 22) criptografa a sessão remota. Telnet (23), FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."}, {id:"s302",t:"secplus",d:"d3",q:"AES é um exemplo de criptografia:", o:["Simétrica (mesma chave cifra e decifra)","Assimétrica (par de chaves)","Hash de mão única","Codificação Base64"],c:0, e:"AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id:"s303",t:"secplus",d:"d3",q:"MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o:["Senha, PIN e resposta secreta","Algo que sabe, algo que tem, algo que é","3 senhas diferentes","Usuário, senha e e-mail"],c:1, e:"MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."}, {id:"s304",t:"secplus",d:"d3",q:"Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o:["Compressão ZIP","Função hash (ex: SHA-256)","Criptografia AES","Assinatura Base64"],c:1, e:"Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."}, {id:"s305",t:"secplus",d:"d3",q:"Uma característica de HASH (diferente de criptografia) é que ele:", o:["Pode ser revertido com a chave","É de mão única (não reversível)","Sempre encurta o texto pela metade","Precisa de par de chaves"],c:1, e:"Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id:"s306",t:"secplus",d:"d3",q:"Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o:["VPN (ex: IPsec/TLS)","DNS","DHCP","SNMP"],c:0, e:"VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome, DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // ===== SECURITY+ D4 — Operações/Resposta ===== {id:"s401",t:"secplus",d:"d4",q:"Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?", o: ["Erradicação","Preparação","Recuperação","Contenção"],c:1, e:"Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas. Preparar (plano, ferramentas, treino) vem antes de tudo."}, {id:"s402",t:"secplus",d:"d4",q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o:["Firewall","SIEM","Proxy","Antivírus"],c:1, e:"SIEM (Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC."}, {id:"s403",t:"secplus",d:"d4",q:"Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o:["O HD / disco","A memória RAM (dados voláteis)","Os backups em fita","Os logs impressos"],c:1, e:"O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco →

depois backups. Captura o volátil antes que evapore."},

{id:"s404",t:"secplus",d:"d4",q:"Depois de conter e erradicar um ataque, a fase que documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC =====

{id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO você aceita perder","Quanto TEMPO o serviço pode ficar fora","O custo do incidente","O número de usuários afetados"],c:1, e:"RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder)."},

{id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) mede:", o:["Quanto TEMPO pra voltar ao ar","Quanto DADO (janela) você aceita perder","A gravidade da vulnerabilidade","O SLA do fornecedor"],c:1, e:"RPO = quanto de dado (medido em tempo desde o último backup) você tolera perder. RPO de 1h = backups de hora em hora. RTO é sobre tempo de retorno."}, {id:"s503",t:"secplus",d:"d5",q:"Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?", o:["Aceitar o risco","Evitar o risco","Transferir o risco","Mitigar o risco"],c:2, e:"Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele."}, // ===== SECURITY+ — cadeia de ataque moderna + termos de mercado (vagas reais) =====

{id:"s107",t:"secplus",d:"d1",q:"Malware que rouba senhas salvas no navegador, cookies e carteiras e manda pro atacante é um:", o:["Infostealer","Adware","Keylogger de hardware","Rootkit de firmware"],c:0, e:"Infostealer rouba credenciais JÁ salvas. Hoje é a porta de entrada nº1: o crime compra essas credenciais vazadas e entra sem 'hackear'. Foi o passo 1 do ataque."}, {id:"s108",t:"secplus",d:"d1",q:"No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?", o:["Firewall mal configurado","Phishing + VPN sem MFA / credencial vazada","Cabo de rede exposto","Falta de antivírus"],c:1, e:"A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1."}, {id:"s109",t:"secplus",d:"d1",q:"Ferramenta clássica pra roubar hashes/credenciais da memória do Windows e fazer movimento lateral:", o:["Wireshark","Mimikatz","Nmap","Nessus"],c:1, e:"Mimikatz extrai hashes/tickets da memória → o atacante pula de máquina em máquina (movimento lateral) até virar Domain Admin. Wireshark fareja rede, Nmap escaneia porta, Nessus escaneia vulnerabilidade."}, {id:"s110",t:"secplus",d:"d1",q:"Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:", o:["Escalada de privilégio (privilege escalation)","Negação de serviço","Engenharia social","Sniffing"],c:0, e:"Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia."}, {id:"s111",t:"secplus",d:"d4",q:"O atacante COPIA os dados pra fora ANTES de criptografar. Esse roubo de dados é a:", o:["Exfiltração","Contenção","Sanitização","Ofuscação"],c:0, e:"Exfiltração = tirar os dados da rede. No ransomware moderno vem ANTES da criptografia, pra permitir a chantagem de

vazamento (dupla extorsão)."}, {id:"s112",t:"secplus",d:"d1",q:"'Tripla extorsão' no ransomware combina:", o:["Três vírus diferentes","Criptografar + ameaçar vazár dados + chantagear os clientes da vítima","Pedir resgate 3 vezes","Atacar 3 empresas juntas"],c:1, e:"Camada 1: criptografa e cobra a chave. Camada 2: ameaça publicar os dados roubados. Camada 3: extorquer também os clientes cujos dados vazaram. Por isso backup sozinho não basta mais."}, {id:"s113",t:"secplus",d:"d1",q:"A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:", o:["OWASP Top 10","MITRE ATT&CK","ISO 27001","PCI-DSS"],c:1, e:"MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão."}, {id:"s114",t:"secplus",d:"d4",q:"Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o:["SIEM","SOAR","EDR","VPN"],c:1, e:"SOAR (Orchestration, Automation & Response) roda playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta."}, {id:"s115",t:"secplus",d:"d3",q:"Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o:["EDR","DLP","IDS de rede","Proxy"],c:0, e:"EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede."}, {id:"s116",t:"secplus",d:"d3",q:"Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o:["DLP (Data Loss Prevention)","SSO","MFA","VPN"],c:0, e:"DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum barra o vazamento em si."}, {id:"s117",t:"secplus",d:"d5",q:"O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o:["Instalar, Atualizar, Testar, Auditar, Arquivar","Identificar, Proteger, Detectar, Responder, Recuperar","Planejar, Fazer, Checar, Agir, Revisar","Prevenir, Punir, Prever, Provar, Publicar"],c:1, e:"NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Governar — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista."}, {id:"s118",t:"secplus",d:"d5",q:"PEGADINHA: 'SOC 2' significa:", o:["O time de analistas (Security Operations Center)","Um relatório de auditoria dos controles de uma empresa","Um tipo de firewall","Uma fase da resposta a incidente"],c:1, e:"SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes."}, {id:"s119",t:"secplus",d:"d5",q:"HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o:["Saúde (US) / Financeiro (US) / Pessoais (UE)","Governo / Militar / Escolar","Cartão / Senha / Biometria","Nuvem / Rede / Endpoint"],c:0, e:"HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC."}, {id:"s120",t:"secplus",d:"d4",q:"A 'Cyber Kill Chain' descreve o quê?", o:["As fases de um ataque, do reconhecimento à ação final","Um tipo de criptografia","Uma lei de proteção de dados","Uma ferramenta de varredura"],c:0, e:"Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo."},

{id:"s121",t:"secplus",d:"d3",q:"Diferença entre IDS e IPS:", o:["IDS detecta e alerta; IPS detecta e BLOQUEIA","São a mesma coisa","IDS é de disco; IPS é de rede","IPS só grava log"],c:0, e:"IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção."}, {id:"s122",t:"secplus",d:"d3",q:"O que a PKI (infraestrutura de chave pública) sustenta na prática?", o:["Certificados digitais (o cadeado do HTTPS)","O antivírus","O backup em nuvem","A senha do Wi-Fi"],c:0, e:"PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."}, {id:"s123",t:"secplus",d:"d3",q:"SAST e DAST testam segurança de software. A diferença:", o:["SAST lê o código PARADO; DAST testa a app RODANDO","SAST é pago; DAST é grátis","São sinônimos","SAST é de rede; DAST é de disco"],c:0, e:"SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id:"s124",t:"secplus",d:"d5",q:"ISO/IEC 27001 é:", o:["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)","Uma lei dos EUA","Um tipo de firewall","Um scanner de vulnerabilidade"],c:0, e:"ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id:"s125",t:"secplus",d:"d5",q:"TPRM (Third-Party Risk Management) trata de:", o:["Avaliar o risco de segurança dos FORNECEDORES/terceiros","Testar a própria rede","Treinar funcionários","Criptografar backup"],c:0, e:"TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, // ===== SECURITY+ — lote extra (volume de simulado) ===== {id:"s130",t:"secplus",d:"d1",q:"Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A)** DDoS
- B)** Phishing
- C)** SQL injection
- D)** Escalada de privilégio

2. Malware que criptografa teus arquivos e exige pagamento pra devolver é:", o:
 ["Spyware","Ransomware","Rootkit","Worm"],c:1, e:"Ransomware sequestra os dados por criptografia e cobra resgate. Spyware espiona; rootkit se esconde no sistema com privilégio; worm se autopropaga na rede.", {id:"s103",t:"secplus",d:"d1",q:"Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:", o:["CVE pública","Zero-day","Backdoor","Falso positivo"],c:1, e:"Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção."}, {id:"s104",t:"secplus",d:"d1",q:"Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:", o:["Ataque on-path (MITM)","Negação de serviço","SQL injection","Força bruta"],c:0, e:"On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas."}, {id:"s105",t:"secplus",d:"d1",q:"Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:", o: ["Escassez","Autoridade + urgência","Prova social","Reciprocidade"],c:1, e:"Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro."}, {id:"s106",t:"secplus",d:"d1",q:"Injeção de comando SQL num campo de login explora principalmente a falta de:", o:["Criptografia do disco","Validação de entrada (input)","Backup","Antivírus"],c:1, e:"SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa."}, // ===== SECURITY+ D2 — Arquitetura =====
 {id:"s201",t:"secplus",d:"d2",q:"O princípio 'nunca confie, sempre verifique' — mesmo dentro da rede — é o modelo:", o:["Defesa em profundidade","Zero Trust","Air gap","Menor privilégio"],c:1, e:"Zero Trust assume que ninguém é confiável por padrão, nem quem já está dentro. Verifica cada acesso. Menor privilégio é complementar, mas é outro conceito."}, {id:"s202",t:"secplus",d:"d2",q:"Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:", o:["Menor privilégio","Separação de funções","Rotação de cargo","Need-to-know geográfico"],c:0, e:"Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida."}, {id:"s203",t:"secplus",d:"d2",q:"Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:", o:["VLAN de voz","DMZ (screened subnet)","VPN","Intranet"],c:1, e:"DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno."}, {id:"s204",t:"secplus",d:"d2",q:"Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:", o:["Zero Trust","Defesa em profundidade","Fail-open","Segurança por obscuridade"],c:1, e:"Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger)."}, // ===== SECURITY+ D3 — Implementação =====
 {id:"s301",t:"secplus",d:"d3",q:"Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o:

["Telnet","SSH","FTP","HTTP"],c:1, e:"SSH (porta 22) criptografa a sessão remota. Telnet (23), FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."}, {id:"s302",t:"secplus",d:"d3",q:"AES é um exemplo de criptografia:", o:["Simétrica (mesma chave cifra e decifra)","Assimétrica (par de chaves)","Hash de mão única","Codificação Base64"],c:0, e:"AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id:"s303",t:"secplus",d:"d3",q:"MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o:["Senha, PIN e resposta secreta","Algo que sabe, algo que tem, algo que é","3 senhas diferentes","Usuário, senha e e-mail"],c:1, e:"MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."}, {id:"s304",t:"secplus",d:"d3",q:"Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o:["Compressão ZIP","Função hash (ex: SHA-256)","Criptografia AES","Assinatura Base64"],c:1, e:"Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."}, {id:"s305",t:"secplus",d:"d3",q:"Uma característica de HASH (diferente de criptografia) é que ele:", o:["Pode ser revertido com a chave","É de mão única (não reversível)","Sempre encurta o texto pela metade","Precisa de par de chaves"],c:1, e:"Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id:"s306",t:"secplus",d:"d3",q:"Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o:["VPN (ex: IPsec/TLS)","DNS","DHCP","SNMP"],c:0, e:"VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome, DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // ===== SECURITY+ D4 — Operações/Resposta ===== {id:"s401",t:"secplus",d:"d4",q:"Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?", o: ["Erradicação","Preparação","Recuperação","Contenção"],c:1, e:"Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas. Preparar (plano, ferramentas, treino) vem antes de tudo."}, {id:"s402",t:"secplus",d:"d4",q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o:["Firewall","SIEM","Proxy","Antivírus"],c:1, e:"SIEM (Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC."}, {id:"s403",t:"secplus",d:"d4",q:"Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o:["O HD / disco","A memória RAM (dados voláteis)","Os backups em fita","Os logs impressos"],c:1, e:"O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco → depois backups. Captura o volátil antes que evapore."}, {id:"s404",t:"secplus",d:"d4",q:"Depois de conter e erradicar um ataque, a fase que documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC ===== {id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO

you accept losing", "How much TIME the service can be out", "The cost of the incident", "The number of users affected"], c:1, e: "RTO = maximum acceptable downtime (how fast they have to come back). Do not confuse with RPO (how much data can be lost).", {id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) means:", o:["How much TIME to come back", "How much DATA (data) you accept losing", "The severity of vulnerability", "The SLA of the provider"], c:1, e: "RPO = how much data (measured in time since the last backup) you can tolerate losing. RPO of 1h = hourly backups. RTO is about time to return.", {id:"s503",t:"secplus",d:"d5",q:"Hiring a cyber insurance to cover the loss of an attack is what is the response to the risk?", o:["Accept the risk", "Avoid the risk", "Transfer the risk", "Mitigate the risk"], c:2, e: "Transfer: you pass the financial impact to a third party (insurer). Mitigate = reduce with controls; avoid = not doing the activity; accept = live with it.", // ===== SECURITY+ — chain of attack modern + market terms (real wages) ===== {id:"s107",t:"secplus",d:"d1",q:"Malware that steals passwords saved in the browser, cookies and wallets and sends them to the attacker is:", o:["Infostealer", "Adware", "Keylogger hardware", "Rootkit of firmware"], c:0, e: "Infostealer steals credentials ALREADY saved. Today is the door of entry nº1: the crime buys these credentials and enters without 'hacking'. It is step 1 of the attack.", {id:"s108",t:"secplus",d:"d1",q:"No 'initial access' of a modern ransomware, what is the flaw MORE explored?", o:["Firewall misconfigured", "Phishing + VPN without MFA / credential leaked", "Network cable exposed", "Lack of antivirus"], c:1, e: "The entry is almost always human/credential: phishing, VPN without second factor, or login leaked by infostealer. For this reason MFA in EVERYTHING is the defense nº1.", {id:"s109",t:"secplus",d:"d1",q:"Classic tool for stealing hashes/credentials from Windows memory and making lateral movement:", o:["Wireshark", "Mimikatz", "Nmap", "Nessus"], c:1, e: "Mimikatz extracts hashes/tickets from memory → the attacker jumps from machine to machine (lateral movement) until becoming Domain Admin. Wireshark sniffs network, Nmap scans port, Nessus scans vulnerability.", {id:"s110",t:"secplus",d:"d1",q:"Attacker enters as a common user and becomes 'Domain Admin'. This gain of power is:", o:["Privilege escalation (privilege escalation)", "Denial of service", "Social engineering", "Sniffing"], c:0, e: "Privilege escalation = going from low access to administrator. Becoming Domain Admin gives control of the entire domain (all machines and accounts). It is step 2 of the chain.", {id:"s111",t:"secplus",d:"d4",q:"The attacker COPIES the data before encrypting. This theft of data is:", o:["Exfiltration", "Containment", "Sanitization", "Obfuscation"], c:0, e: "Exfiltration = taking data from the network. In modern ransomware it comes BEFORE encryption, to allow for extortion (double extortion).", {id:"s112",t:"secplus",d:"d1",q:"'Triple extortion' in ransomware combines:", o:["Three different viruses", "Encrypting + threatening to leak data + extorting the victims", "Demanding ransom 3 times", "Attacking 3 companies together"], c:1, e: "Layer 1: encrypts and demands the key. Layer 2: threatens to publish the stolen data. Layer 3: extorts the victims whose data was leaked. For this reason backup alone is not enough.", {id:"s113",t:"secplus",d:"d1",q:"The 'encyclopedia' of tactics and techniques of attackers that the SOC uses as a map is:", o:["OWASP Top 10", "MITRE ATT&CK", "ISO

27001", "PCI-DSS"], c:1, e: "MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão.", {id:"s114", t:"secplus", d:"d4", q: "Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o: ["SIEM", "SOAR", "EDR", "VPN"], c:1, e: "SOAR (Orchestration, Automation & Response) roda playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta.", {id:"s115", t:"secplus", d:"d3", q: "Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o: ["EDR", "DLP", "IDS de rede", "Proxy"], c:0, e: "EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede.", {id:"s116", t:"secplus", d:"d3", q: "Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o: ["DLP (Data Loss Prevention)", "SSO", "MFA", "VPN"], c:0, e: "DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum barra o vazamento em si.", {id:"s117", t:"secplus", d:"d5", q: "O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o: ["Instalar, Atualizar, Testar, Auditar, Arquivar", "Identificar, Proteger, Detectar, Responder, Recuperar", "Planejar, Fazer, Checar, Agir, Revisar", "Prevenir, Punir, Prever, Provar, Publicar"], c:1, e: "NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Governar — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista.", {id:"s118", t:"secplus", d:"d5", q: "PEGADINHA: 'SOC 2' significa:", o: ["O time de analistas (Security Operations Center)", "Um relatório de auditoria dos controles de uma empresa", "Um tipo de firewall", "Uma fase da resposta a incidente"], c:1, e: "SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes.", {id:"s119", t:"secplus", d:"d5", q: "HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o: ["Saúde (US) / Financeiro (US) / Pessoais (UE)", "Governo / Militar / Escolar", "Cartão / Senha / Biometria", "Nuvem / Rede / Endpoint"], c:0, e: "HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC.", {id:"s120", t:"secplus", d:"d4", q: "A 'Cyber Kill Chain' descreve o quê?", o: ["As fases de um ataque, do reconhecimento à ação final", "Um tipo de criptografia", "Uma lei de proteção de dados", "Uma ferramenta de varredura"], c:0, e: "Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo.", {id:"s121", t:"secplus", d:"d3", q: "Diferença entre IDS e IPS:", o: ["IDS detecta e alerta; IPS detecta e BLOQUEIA", "São a mesma coisa", "IDS é de disco; IPS é de rede", "IPS só grava log"], c:0, e: "IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção.", {id:"s122", t:"secplus", d:"d3", q: "O que a PKI (infraestrutura de chave pública) sustenta na prática?", o: ["Certificados digitais (o cadeado do HTTPS)", "O antivírus", "O backup em nuvem", "A senha do Wi-Fi"], c:0, e: "PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que

faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."}, {id:"s123",t:"secplus",d:"d3",q:"SAST e DAST testam segurança de software. A diferença:", o: ["SAST lê o código PARADO; DAST testa a app RODANDO","SAST é pago; DAST é grátis","São sinônimos","SAST é de rede; DAST é de disco"],c:0, e:"SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id:"s124",t:"secplus",d:"d5",q:"ISO/IEC 27001 é:", o:["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)","Uma lei dos EUA","Um tipo de firewall","Um scanner de vulnerabilidade"],c:0, e:"ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id:"s125",t:"secplus",d:"d5",q:"TPRM (Third-Party Risk Management) trata de:", o:["Avaliar o risco de segurança dos FORNECEDORES/terceiros","Testar a própria rede","Treinar funcionários","Criptografar backup"],c:0, e:"TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, // ===== SECURITY+ — lote extra (volume de simulado) ===== {id:"s130",t:"secplus",d:"d1",q:"Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A)** DDoS
- B)** Phishing
- C)** SQL injection
- D)** Escalada de privilégio

3. O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o:["Instalar, Atualizar, Testar, Auditar, Arquivar","Identificar, Proteger, Detectar, Responder, Recuperar","Planejar, Fazer, Checar, Agir, Revisar","Prevenir, Punir, Prever, Provar, Publicar"],c:1, e:"NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista."}, {id:"s118",t:"secplus",d:"d5",q:"PEGADINHA: 'SOC 2' significa:", o:["O time de analistas (Security Operations Center)","Um relatório de auditoria dos controles de uma empresa","Um tipo de firewall","Uma fase da resposta a incidente"],c:1, e:"SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes."}, {id:"s119",t:"secplus",d:"d5",q:"HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o:["Saúde (US) / Financeiro (US) / Pessoais (UE)","Governo / Militar / Escolar","Cartão / Senha / Biometria","Nuvem / Rede / Endpoint"],c:0, e:"HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC."}, {id:"s120",t:"secplus",d:"d4",q:"A 'Cyber Kill Chain' descreve o quê?", o:["As fases de um ataque, do reconhecimento à ação final","Um tipo de criptografia","Uma lei de proteção de dados","Uma ferramenta de varredura"],c:0, e:"Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo."}, {id:"s121",t:"secplus",d:"d3",q:"Diferença entre IDS e IPS:", o:["IDS detecta e alerta; IPS detecta e BLOQUEIA","São a mesma coisa","IDS é de disco; IPS é de rede","IPS só grava log"],c:0, e:"IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção."}, {id:"s122",t:"secplus",d:"d3",q:"O que a PKI (infraestrutura de chave pública) sustenta na prática?", o:["Certificados digitais (o cadeado do HTTPS)","O antivírus","O backup em nuvem","A senha do Wi-Fi"],c:0, e:"PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."}, {id:"s123",t:"secplus",d:"d3",q:"SAST e DAST testam segurança de software. A diferença:", o:["SAST lê o código PARADO; DAST testa a app RODANDO","SAST é pago; DAST é grátis","São sinônimos","SAST é de rede; DAST é de disco"],c:0, e:"SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id:"s124",t:"secplus",d:"d5",q:"ISO/IEC 27001 é:", o:["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)","Uma lei dos EUA","Um tipo de firewall","Um scanner de vulnerabilidade"],c:0, e:"ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id:"s125",t:"secplus",d:"d5",q:"TPRM (Third-Party Risk Management) trata de:", o:["Avaliar o risco de segurança dos FORNECEDORES/terceiros","Testar a própria rede","Treinar funcionários","Criptografar

backup"],c:0, e:"TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, //

===== SECURITY+ — lote extra (volume de simulado) =====

{id:"s130",t:"secplus",d:"d1",q:"Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A)** DDoS
- B)** Phishing
- C)** SQL injection
- D)** Escalada de privilégio

4. O princípio 'nunca confie, sempre verifique' — mesmo dentro da rede — é o modelo:", o: ["Defesa em profundidade", "Zero Trust", "Air gap", "Menor privilégio"], c: 1, e: "Zero Trust assume que ninguém é confiável por padrão, nem quem já está dentro. Verifica cada acesso. Menor privilégio é complementar, mas é outro conceito."}, {id: "s202", t: "secplus", d: "d2", q: "Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:", o: ["Menor privilégio", "Separação de funções", "Rotação de cargo", "Need-to-know geográfico"], c: 0, e: "Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida."}, {id: "s203", t: "secplus", d: "d2", q: "Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:", o: ["VLAN de voz", "DMZ (screened subnet)", "VPN", "Intranet"], c: 1, e: "DMZ / screened subnet fica entre a internet e a rede interna: o que precisa ser público mora lá, e um comprometimento não alcança direto o interno."}, {id: "s204", t: "secplus", d: "d2", q: "Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:", o: ["Zero Trust", "Defesa em profundidade", "Fail-open", "Segurança por obscuridade"], c: 1, e: "Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger)."}, // ===== SECURITY+ D3 — Implementação ===== {id: "s301", t: "secplus", d: "d3", q: "Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o: ["Telnet", "SSH", "FTP", "HTTP"], c: 1, e: "SSH (porta 22) criptografa a sessão remota. Telnet (23), FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."}, {id: "s302", t: "secplus", d: "d3", q: "AES é um exemplo de criptografia:", o: ["Simétrica (mesma chave cifra e decifra)", "Assimétrica (par de chaves)", "Hash de mão única", "Codificação Base64"], c: 0, e: "AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id: "s303", t: "secplus", d: "d3", q: "MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o: ["Senha, PIN e resposta secreta", "Algo que sabe, algo que tem, algo que é", "3 senhas diferentes", "Usuário, senha e e-mail"], c: 1, e: "MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."}, {id: "s304", t: "secplus", d: "d3", q: "Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o: ["Compressão ZIP", "Função hash (ex: SHA-256)", "Criptografia AES", "Assinatura Base64"], c: 1, e: "Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."}, {id: "s305", t: "secplus", d: "d3", q: "Uma característica de HASH (diferente de criptografia) é que ele:", o: ["Pode ser revertido com a chave", "É de mão única (não reversível)", "Sempre encurta o texto pela metade", "Precisa de par de chaves"], c: 1, e: "Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id: "s306", t: "secplus", d: "d3", q: "Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o: ["VPN (ex: IPsec/TLS)", "DNS", "DHCP", "SNMP"], c: 0, e: "VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome,

DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // ===== SECURITY+ D4 — Operações/Resposta ===== {id:"s401",t:"secplus",d:"d4",q:"Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?", o: ["Erradicação","Preparação","Recuperação","Contenção"],c:1, e:"Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas. Preparar (plano, ferramentas, treino) vem antes de tudo."}, {id:"s402",t:"secplus",d:"d4",q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o:["Firewall","SIEM","Proxy","Antivírus"],c:1, e:"SIEM (Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC."}, {id:"s403",t:"secplus",d:"d4",q:"Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o:["O HD / disco","A memória RAM (dados voláteis)","Os backups em fita","Os logs impressos"],c:1, e:"O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco → depois backups. Captura o volátil antes que evapore."}, {id:"s404",t:"secplus",d:"d4",q:"Depois de conter e erradicar um ataque, a fase que documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC ===== {id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO você aceita perder","Quanto TEMPO o serviço pode ficar fora","O custo do incidente","O número de usuários afetados"],c:1, e:"RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder)."}, {id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) mede:", o:["Quanto TEMPO pra voltar ao ar","Quanto DADO (janela) você aceita perder","A gravidade da vulnerabilidade","O SLA do fornecedor"],c:1, e:"RPO = quanto de dado (medido em tempo desde o último backup) você tolera perder. RPO de 1h = backups de hora em hora. RTO é sobre tempo de retorno."}, {id:"s503",t:"secplus",d:"d5",q:"Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?", o:["Aceitar o risco","Evitar o risco","Transferir o risco","Mitigar o risco"],c:2, e:"Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele."}, // ===== SECURITY+ — cadeia de ataque moderna + termos de mercado (vagas reais) ===== {id:"s107",t:"secplus",d:"d1",q:"Malware que rouba senhas salvas no navegador, cookies e carteiras e manda pro atacante é um:", o:["Infostealer","Adware","Keylogger de hardware","Rootkit de firmware"],c:0, e:"Infostealer rouba credenciais JÁ salvas. Hoje é a porta de entrada nº1: o crime compra essas credenciais vazadas e entra sem 'hackear'. Foi o passo 1 do ataque."}, {id:"s108",t:"secplus",d:"d1",q:"No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?", o:["Firewall mal configurado","Phishing + VPN sem MFA / credencial vazada","Cabo de rede exposto","Falta de antivírus"],c:1, e:"A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO

é a defesa nº1.", {id:"s109",t:"secplus",d:"d1",q:"Ferramenta clássica pra roubar hashes/credenciais da memória do Windows e fazer movimento lateral:", o: ["Wireshark","Mimikatz","Nmap","Nessus"],c:1, e:"Mimikatz extrai hashes/tickets da memória → o atacante pula de máquina em máquina (movimento lateral) até virar Domain Admin. Wireshark fareja rede, Nmap escaneia porta, Nessus escaneia vulnerabilidade."}, {id:"s110",t:"secplus",d:"d1",q:"Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:", o:["Escalada de privilégio (privilege escalation)","Negação de serviço","Engenharia social","Sniffing"],c:0, e:"Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia."}, {id:"s111",t:"secplus",d:"d4",q:"O atacante COPIA os dados pra fora ANTES de criptografar. Esse roubo de dados é a:", o: ["Exfiltração","Contenção","Sanitização","Ofuscação"],c:0, e:"Exfiltração = tirar os dados da rede. No ransomware moderno vem ANTES da criptografia, pra permitir a chantagem de vazamento (dupla extorsão)."}, {id:"s112",t:"secplus",d:"d1",q:"'Tripla extorsão' no ransomware combina:", o:["Três vírus diferentes","Criptografar + ameaçar vaziar dados + chantagear os clientes da vítima","Pedir resgate 3 vezes","Atacar 3 empresas juntas"],c:1, e:"Camada 1: criptografa e cobra a chave. Camada 2: ameaça publicar os dados roubados. Camada 3: extorpe também os clientes cujos dados vazaram. Por isso backup sozinho não basta mais."}, {id:"s113",t:"secplus",d:"d1",q:"A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:", o:["OWASP Top 10","MITRE ATT&CK","ISO 27001","PCI-DSS"],c:1, e:"MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão."}, {id:"s114",t:"secplus",d:"d4",q:"Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o: ["SIEM","SOAR","EDR","VPN"],c:1, e:"SOAR (Orchestration, Automation & Response) roda playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta."}, {id:"s115",t:"secplus",d:"d3",q:"Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o:["EDR","DLP","IDS de rede","Proxy"],c:0, e:"EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede."}, {id:"s116",t:"secplus",d:"d3",q:"Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o:["DLP (Data Loss Prevention)","SSO","MFA","VPN"],c:0, e:"DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum barra o vazamento em si."}, {id:"s117",t:"secplus",d:"d5",q:"O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o:["Instalar, Atualizar, Testar, Auditar, Arquivar","Identificar, Proteger, Detectar, Responder, Recuperar","Planejar, Fazer, Checar, Agir, Revisar","Prevenir, Punir, Prever, Provar, Publicar"],c:1, e:"NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista."}, {id:"s118",t:"secplus",d:"d5",q:"PEGADINHA: 'SOC 2' significa:", o:["O time de analistas (Security Operations Center)","Um relatório de

auditoria dos controles de uma empresa", "Um tipo de firewall", "Uma fase da resposta a incidente"],c:1, e:"SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes."}, {id:"s119",t:"secplus",d:"d5",q:"HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o:["Saúde (US) / Financeiro (US) / Pessoais (UE)","Governo / Militar / Escolar"],"Cartão / Senha / Biometria","Nuvem / Rede / Endpoint"],c:0, e:"HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC."}, {id:"s120",t:"secplus",d:"d4",q:"A 'Cyber Kill Chain' descreve o quê?", o:["As fases de um ataque, do reconhecimento à ação final","Um tipo de criptografia","Uma lei de proteção de dados","Uma ferramenta de varredura"],c:0, e:"Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo."}, {id:"s121",t:"secplus",d:"d3",q:"Diferença entre IDS e IPS:", o:["IDS detecta e alerta; IPS detecta e BLOQUEIA","São a mesma coisa","IDS é de disco; IPS é de rede","IPS só grava log"],c:0, e:"IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção."}, {id:"s122",t:"secplus",d:"d3",q:"O que a PKI (infraestrutura de chave pública) sustenta na prática?", o:["Certificados digitais (o cadeado do HTTPS)","O antivírus","O backup em nuvem","A senha do Wi-Fi"],c:0, e:"PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."}, {id:"s123",t:"secplus",d:"d3",q:"SAST e DAST testam segurança de software. A diferença:", o:["SAST lê o código PARADO; DAST testa a app RODANDO","SAST é pago; DAST é grátis","São sinônimos","SAST é de rede; DAST é de disco"],c:0, e:"SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id:"s124",t:"secplus",d:"d5",q:"ISO/IEC 27001 é:", o:["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)","Uma lei dos EUA","Um tipo de firewall","Um scanner de vulnerabilidade"],c:0, e:"ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id:"s125",t:"secplus",d:"d5",q:"TPRM (Third-Party Risk Management) trata de:", o:["Avaliar o risco de segurança dos FORNECEDORES/terceiros","Testar a própria rede","Treinar funcionários","Criptografar backup"],c:0, e:"TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, // ===== SECURITY+ — lote extra (volume de simulado) ===== {id:"s130",t:"secplus",d:"d1",q:"Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A)** DDoS
- B)** Phishing
- C)** SQL injection

D) Escalada de privilégio

5. Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:, o: ["Zero Trust", "Defesa em profundidade", "Fail-open", "Segurança por obscuridade"], c:1, e: "Defense in depth: camadas sobrepostas. Se uma falha, a próxima segura. Não confundir com Zero Trust (modelo de confiança) nem com obscuridade (esconder ≠ proteger).", // ===== SECURITY+ D3 — Implementação ===== {id:"s301",t:"secplus",d:"d3",q:"Protocolo seguro pra administrar um servidor por linha de comando remota, na porta 22:", o: ["Telnet", "SSH", "FTP", "HTTP"], c:1, e: "SSH (porta 22) criptografa a sessão remota. Telnet (23), FTP (21) e HTTP (80) mandam dados em texto claro — inseguros."}, {id:"s302",t:"secplus",d:"d3",q:"AES é um exemplo de criptografia:", o: ["Simétrica (mesma chave cifra e decifra)", "Assimétrica (par de chaves)", "Hash de mão única", "Codificação Base64"], c:0, e: "AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação."}, {id:"s303",t:"secplus",d:"d3",q:"MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?", o: ["Senha, PIN e resposta secreta", "Algo que sabe, algo que tem, algo que é", "3 senhas diferentes", "Usuário, senha e e-mail"], c:1, e: "MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA."}, {id:"s304",t:"secplus",d:"d3",q:"Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:", o: ["Compressão ZIP", "Função hash (ex: SHA-256)", "Criptografia AES", "Assinatura Base64"], c:1, e: "Hash gera uma 'impressão digital'; se um bit muda, o hash muda. SHA-256 é padrão. AES dá confidencialidade, não integridade por si só."}, {id:"s305",t:"secplus",d:"d3",q:"Uma característica de HASH (diferente de criptografia) é que ele:", o: ["Pode ser revertido com a chave", "É de mão única (não reversível)", "Sempre encurta o texto pela metade", "Precisa de par de chaves"], c:1, e: "Hash é one-way: não dá pra 'descriptografar' de volta. Por isso serve pra guardar senha (compara hashes) e checar integridade."}, {id:"s306",t:"secplus",d:"d3",q:"Protocolo que cria um túnel criptografado pra rede corporativa pela internet:", o: ["VPN (ex: IPsec/TLS)", "DNS", "DHCP", "SNMP"], c:0, e: "VPN encapsula e criptografa o tráfego (IPsec ou TLS) por um túnel. DNS resolve nome, DHCP entrega IP, SNMP monitora — nenhum cria o túnel seguro."}, // ===== SECURITY+ D4 — Operações/Resposta ===== {id:"s401",t:"secplus",d:"d4",q:"Na ordem do NIST de resposta a incidente, o que vem PRIMEIRO?", o: ["Erradicação", "Preparação", "Recuperação", "Contenção"], c:1, e: "Ordem NIST: Preparação → Detecção/Análise → Contenção → Erradicação → Recuperação → Lições aprendidas. Preparar (plano, ferramentas, treino) vem antes de tudo."}, {id:"s402",t:"secplus",d:"d4",q:"Ferramenta que coleta e CORRELACIONA logs de vários sistemas pra achar ameaça é o:", o: ["Firewall", "SIEM", "Proxy", "Antivírus"], c:1, e: "SIEM (Security Information and Event Management) junta logs de tudo e correlaciona pra gerar alerta. É o coração do trabalho do analista SOC."}, {id:"s403",t:"secplus",d:"d4",q:"Coletando evidência forense, a 'ordem de volatilidade' manda capturar primeiro:", o: ["O HD / disco", "A memória RAM (dados voláteis)", "Os backups em fita", "Os logs impressos"], c:1, e: "O mais volátil some primeiro ao desligar: RAM, cache, conexões ativas → depois disco →

depois backups. Captura o volátil antes que evapore."},

{id:"s404",t:"secplus",d:"d4",q:"Depois de conter e erradicar um ataque, a fase que documenta o que aprendeu pra não repetir é:", o:["Detecção","Lições aprendidas (post-mortem)","Preparação","Contenção"],c:1, e:"Lessons learned fecha o ciclo: o que falhou, o que melhorar. Vira input da próxima 'preparação'. É onde a organização de fato amadurece."}, // ===== SECURITY+ D5 — GRC =====

{id:"s501",t:"secplus",d:"d5",q:"RTO (Recovery Time Objective) mede:", o:["Quanto DADO você aceita perder","Quanto TEMPO o serviço pode ficar fora","O custo do incidente","O número de usuários afetados"],c:1, e:"RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder)."},

{id:"s502",t:"secplus",d:"d5",q:"RPO (Recovery Point Objective) mede:", o:["Quanto TEMPO pra voltar ao ar","Quanto DADO (janela) você aceita perder","A gravidade da vulnerabilidade","O SLA do fornecedor"],c:1, e:"RPO = quanto de dado (medido em tempo desde o último backup) você tolera perder. RPO de 1h = backups de hora em hora. RTO é sobre tempo de retorno."}, {id:"s503",t:"secplus",d:"d5",q:"Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?", o:["Aceitar o risco","Evitar o risco","Transferir o risco","Mitigar o risco"],c:2, e:"Transferência: você passa o impacto financeiro pra terceiro (seguradora). Mitigar = reduzir com controles; evitar = não fazer a atividade; aceitar = conviver com ele."}, // ===== SECURITY+ — cadeia de ataque moderna + termos de mercado (vagas reais) =====

{id:"s107",t:"secplus",d:"d1",q:"Malware que rouba senhas salvas no navegador, cookies e carteiras e manda pro atacante é um:", o:["Infostealer","Adware","Keylogger de hardware","Rootkit de firmware"],c:0, e:"Infostealer rouba credenciais JÁ salvas. Hoje é a porta de entrada nº1: o crime compra essas credenciais vazadas e entra sem 'hackear'. Foi o passo 1 do ataque."}, {id:"s108",t:"secplus",d:"d1",q:"No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?", o:["Firewall mal configurado","Phishing + VPN sem MFA / credencial vazada","Cabo de rede exposto","Falta de antivírus"],c:1, e:"A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1."}, {id:"s109",t:"secplus",d:"d1",q:"Ferramenta clássica pra roubar hashes/credenciais da memória do Windows e fazer movimento lateral:", o:["Wireshark","Mimikatz","Nmap","Nessus"],c:1, e:"Mimikatz extrai hashes/tickets da memória → o atacante pula de máquina em máquina (movimento lateral) até virar Domain Admin. Wireshark fareja rede, Nmap escaneia porta, Nessus escaneia vulnerabilidade."}, {id:"s110",t:"secplus",d:"d1",q:"Atacante entra como usuário comum e vira 'Domain Admin'. Esse ganho de poder é:", o:["Escalada de privilégio (privilege escalation)","Negação de serviço","Engenharia social","Sniffing"],c:0, e:"Privilege escalation = subir de acesso baixo pra administrador. Virar Domain Admin dá controle do domínio inteiro (todas as máquinas e contas). É o passo 2 da cadeia."}, {id:"s111",t:"secplus",d:"d4",q:"O atacante COPIA os dados pra fora ANTES de criptografar. Esse roubo de dados é a:", o:["Exfiltração","Contenção","Sanitização","Ofuscação"],c:0, e:"Exfiltração = tirar os dados da rede. No ransomware moderno vem ANTES da criptografia, pra permitir a chantagem de

vazamento (dupla extorsão)."}, {id:"s112",t:"secplus",d:"d1",q:"'Tripla extorsão' no ransomware combina:", o:["Três vírus diferentes","Criptografar + ameaçar vazár dados + chantagear os clientes da vítima","Pedir resgate 3 vezes","Atacar 3 empresas juntas"],c:1, e:"Camada 1: criptografa e cobra a chave. Camada 2: ameaça publicar os dados roubados. Camada 3: extorquer também os clientes cujos dados vazaram. Por isso backup sozinho não basta mais."}, {id:"s113",t:"secplus",d:"d1",q:"A 'enciclopédia' de táticas e técnicas de atacantes que o SOC usa como mapa é:", o:["OWASP Top 10","MITRE ATT&CK","ISO 27001","PCI-DSS"],c:1, e:"MITRE ATT&CK cataloga TTPs (táticas/técnicas) reais dos atacantes; o SOC mapeia alertas contra ela. OWASP é falha de aplicação; ISO 27001 é gestão; PCI-DSS é cartão."}, {id:"s114",t:"secplus",d:"d4",q:"Plataforma que AUTOMATIZA a resposta do SOC (ex: isolar a máquina sozinha ao ver o alerta) é:", o:["SIEM","SOAR","EDR","VPN"],c:1, e:"SOAR (Orchestration, Automation & Response) roda playbooks automáticos: o SIEM DETECTA, o SOAR AGE (bloqueia IP, isola host, abre ticket) sem humano. Acelera a resposta."}, {id:"s115",t:"secplus",d:"d3",q:"Evolução do antivírus que monitora e RESPONDE à ameaça direto no dispositivo é:", o:["EDR","DLP","IDS de rede","Proxy"],c:0, e:"EDR (Endpoint Detection & Response) vê comportamento suspeito no endpoint e pode isolar/reverter. DLP impede vazamento de dado; IDS/proxy são de rede."}, {id:"s116",t:"secplus",d:"d3",q:"Controle que impede um funcionário de enviar uma planilha confidencial pra fora da empresa é:", o:["DLP (Data Loss Prevention)","SSO","MFA","VPN"],c:0, e:"DLP monitora e bloqueia dado sensível saindo (e-mail, USB, upload). SSO é login único; MFA é fator extra; VPN é túnel — nenhum barra o vazamento em si."}, {id:"s117",t:"secplus",d:"d5",q:"O framework NIST CSF organiza a segurança em 5 funções. Quais são?", o:["Instalar, Atualizar, Testar, Auditar, Arquivar","Identificar, Proteger, Detectar, Responder, Recuperar","Planejar, Fazer, Checar, Agir, Revisar","Prevenir, Punir, Prever, Provar, Publicar"],c:1, e:"NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na prova e na entrevista."}, {id:"s118",t:"secplus",d:"d5",q:"PEGADINHA: 'SOC 2' significa:", o:["O time de analistas (Security Operations Center)","Um relatório de auditoria dos controles de uma empresa","Um tipo de firewall","Uma fase da resposta a incidente"],c:1, e:"SOC 2 (auditoria) ≠ SOC (Security Operations Center, o time). SOC 2 é o relatório que uma empresa SaaS mostra pra provar que tem controles. Mesma sigla, coisas totalmente diferentes."}, {id:"s119",t:"secplus",d:"d5",q:"HIPAA, GLBA e GDPR protegem, respectivamente, dados de:", o:["Saúde (US) / Financeiro (US) / Pessoais (UE)","Governo / Militar / Escolar","Cartão / Senha / Biometria","Nuvem / Rede / Endpoint"],c:0, e:"HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC."}, {id:"s120",t:"secplus",d:"d4",q:"A 'Cyber Kill Chain' descreve o quê?", o:["As fases de um ataque, do reconhecimento à ação final","Um tipo de criptografia","Uma lei de proteção de dados","Uma ferramenta de varredura"],c:0, e:"Cyber Kill Chain (Lockheed Martin) modela o ataque em fases (reconhecimento → entrega → exploração → instalação → comando/controle → ação). Entender as fases ajuda a cortar o ataque cedo."},

{id:"s121",t:"secplus",d:"d3",q:"Diferença entre IDS e IPS:", o:["IDS detecta e alerta; IPS detecta e BLOQUEIA","São a mesma coisa","IDS é de disco; IPS é de rede","IPS só grava log"],c:0, e:"IDS (Intrusion Detection System) só AVISA. IPS (Prevention) fica no caminho do tráfego e BLOQUEIA ativamente. O 'P' = Prevenção."}, {id:"s122",t:"secplus",d:"d3",q:"O que a PKI (infraestrutura de chave pública) sustenta na prática?", o:["Certificados digitais (o cadeado do HTTPS)","O antivírus","O backup em nuvem","A senha do Wi-Fi"],c:0, e:"PKI emite e gerencia certificados digitais (par de chaves + autoridade certificadora). É o que faz o HTTPS/TLS confiar num site. Base da criptografia assimétrica e da assinatura digital."}, {id:"s123",t:"secplus",d:"d3",q:"SAST e DAST testam segurança de software. A diferença:", o:["SAST lê o código PARADO; DAST testa a app RODANDO","SAST é pago; DAST é grátis","São sinônimos","SAST é de rede; DAST é de disco"],c:0, e:"SAST (Static) analisa o código-fonte sem rodar. DAST (Dynamic) ataca a aplicação em execução, de fora, como um hacker. SCA (extra) acha falha nas bibliotecas de terceiros. Trio do DevSecOps."}, {id:"s124",t:"secplus",d:"d5",q:"ISO/IEC 27001 é:", o:["A norma INTERNACIONAL de gestão de segurança da informação (SGSI)","Uma lei dos EUA","Um tipo de firewall","Um scanner de vulnerabilidade"],c:0, e:"ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR)."}, {id:"s125",t:"secplus",d:"d5",q:"TPRM (Third-Party Risk Management) trata de:", o:["Avaliar o risco de segurança dos FORNECEDORES/terceiros","Testar a própria rede","Treinar funcionários","Criptografar backup"],c:0, e:"TPRM avalia se os fornecedores/parceiros que acessam teus dados são seguros — vazamento deles vira teu problema. Área forte e MUITO remota de GRC."}, // ===== SECURITY+ — lote extra (volume de simulado) =====
{id:"s130",t:"secplus",d:"d1",q:"Ataque que inunda um serviço com tráfego de MILHARES de máquinas infectadas (botnet) pra derrubá-lo:

- A)** DDoS
- B)** Phishing
- C)** SQL injection
- D)** Escalada de privilégio

6. MFA exige pelo menos dois fatores de autenticação. Qual combinação representa autenticação de múltiplos fatores genuína?

- A)** Senha + PIN
- B)** Senha + Token físico
- C)** Dois tipos de biometria
- D)** Pergunta de segurança + Senha

7. Qual dispositivo de segurança de rede opera na camada de aplicação (Layer 7) e pode inspecionar conteúdo HTTP/HTTPS?

- A)** Firewall stateful tradicional
- B)** Web Application Firewall (WAF)
- C)** Switch Layer 2
- D)** Hub

8. Qual a principal diferença entre IDS e IPS?

- A)** IDS bloqueia ataques, IPS apenas detecta
- B)** IDS apenas detecta e alerta, IPS pode bloquear ativamente
- C)** IDS é físico, IPS é virtual
- D)** IDS opera em camada 2, IPS em camada 3

9. No modelo Zero Trust, qual é o princípio fundamental?

- A)** Confiar sempre em usuários internos
- B)** Confiar mas verificar
- C)** Nunca confiar, sempre verificar
- D)** Confiar apenas em VPNs

10. De acordo com o NIST, qual é a primeira fase do ciclo de resposta a incidentes?

- A)** Detecção e Análise
- B)** Preparação
- C)** Contenção
- D)** Recuperação

GABARITO COMENTADO

- 1) A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 2) A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 3) A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 4) A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 5) A — DDoS.** DDoS (Distributed Denial of Service) usa botnet pra sobrecarregar o alvo. DoS é de uma origem só; DDoS é distribuído.
- 6) B — Senha + Token físico.** MFA verdadeira combina fatores de categorias diferentes: algo que você sabe (senha) + algo que você tem (token físico). Múltiplos fatores da mesma categoria não constituem MFA.
- 7) B — Web Application Firewall (WAF).** WAF opera na camada 7 do modelo OSI, inspecionando tráfego HTTP/HTTPS para proteger aplicações web contra ataques como SQL injection e XSS.
- 8) B — IDS apenas detecta e alerta, IPS pode bloquear ativamente.** IDS (Sistema de Detecção de Intrusão) monitora e alerta sobre atividades suspeitas. IPS (Sistema de Prevenção de Intrusão) está posicionado inline e pode bloquear/prevenir ataques automaticamente.
- 9) C — Nunca confiar, sempre verificar.** Zero Trust opera no princípio de 'nunca confiar, sempre verificar' ou 'never trust, always verify', eliminando confiança implícita baseada em localização de rede.
- 10) B — Preparação.** O framework NIST de resposta a incidentes tem 4 fases: Preparação, Detecção e Análise, Contenção/Erradicação/Recuperação, e Atividades Pós-Incidente. Preparação é a primeira.